

TECHNICAL DETAIL

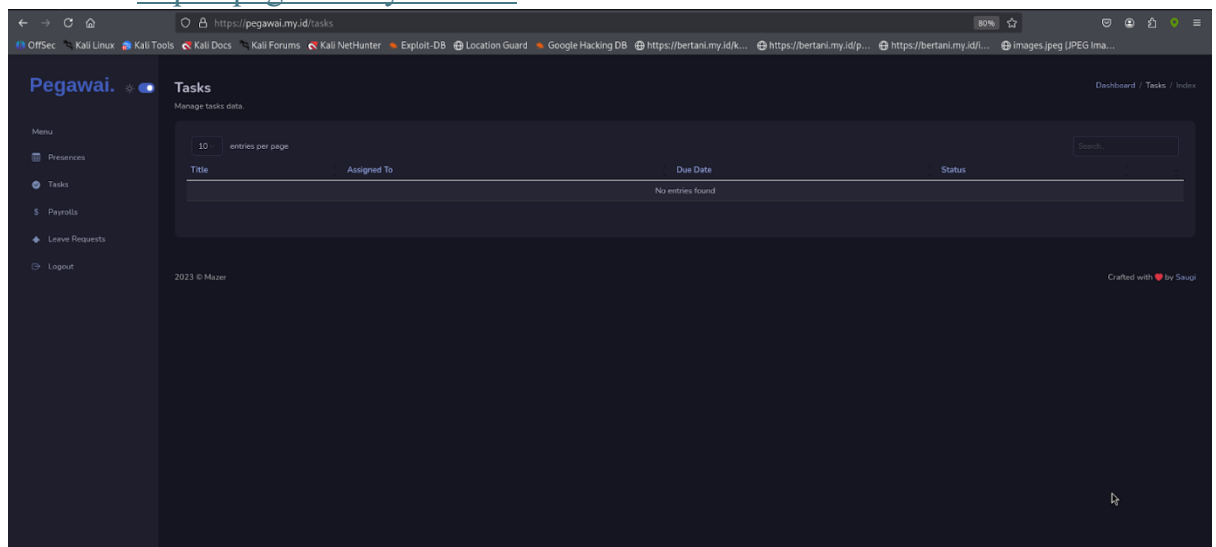
Title	Insecure Direct Object Reference (IDOR) / Broken Access Control on Edit Task Endpoint
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/tasks/edit
Severity	High
CVSS Score	7.1 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:L)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

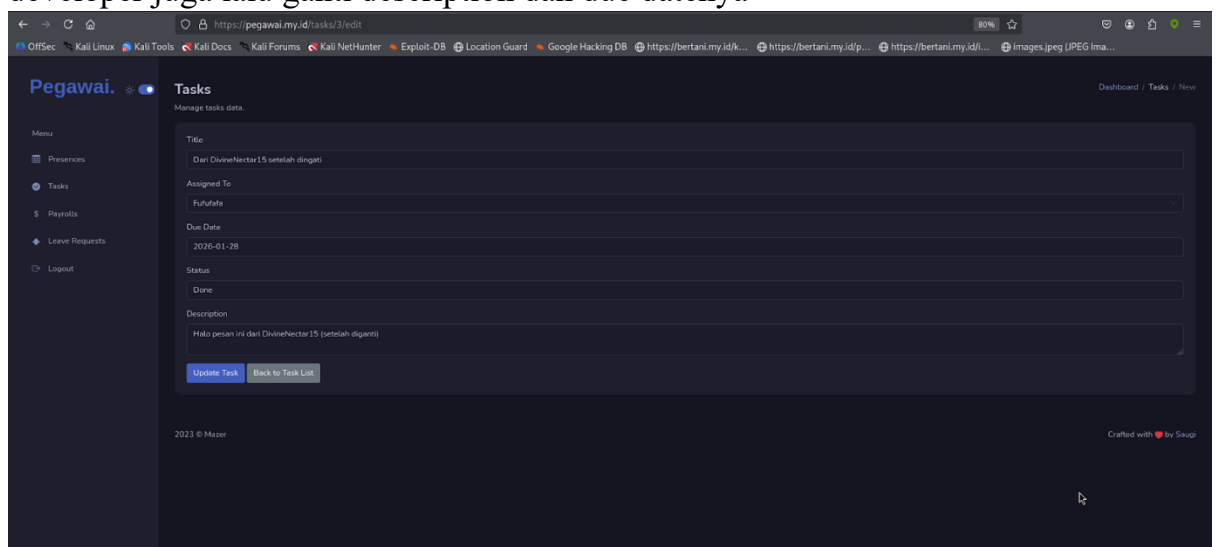
Ditemukan kerentanan jenis Broken Access Control (IDOR) pada fungsi pengeditan tugas. Meskipun antarmuka pengguna (UI) untuk akun dengan *role* "developer" tidak menampilkan tombol/fitur "Edit", pengguna dapat mengakses fungsi tersebut secara ilegal dengan memanipulasi URL secara langsung (URL Crafting). Hal ini memungkinkan pengguna untuk mengubah data tugas milik pengguna lain tanpa otorisasi yang valid

STEPS TO REPRODUCE

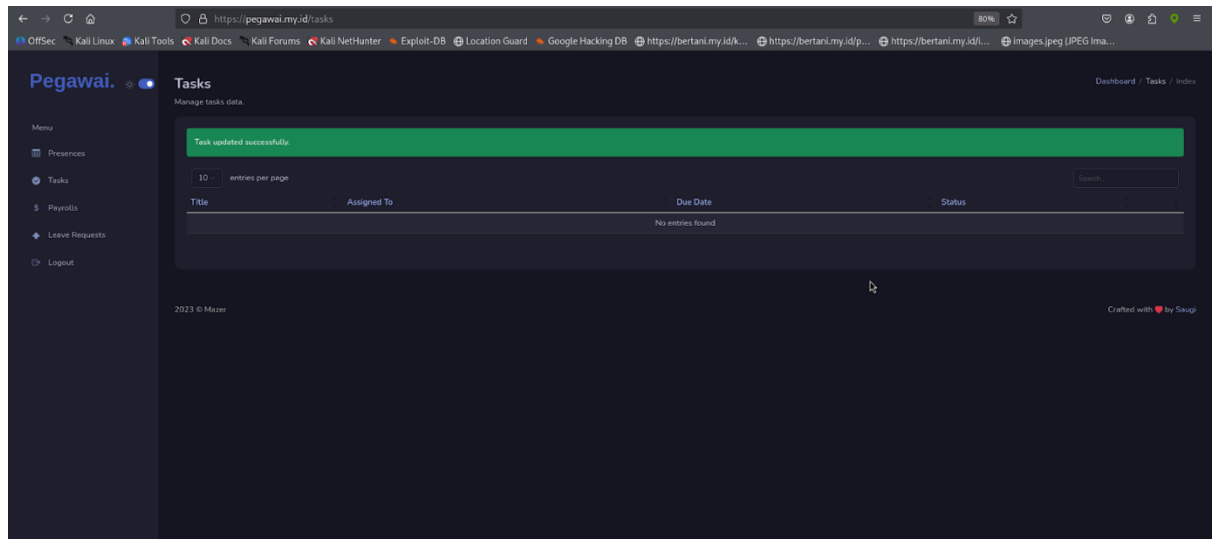
1. Login ke akun Anda yang memiliki role developer
2. Buka url <https://pegawai.my.id/tasks> disini terlihat tidak ada fitur edit



3. Lalu tambahkan /edit menjadi <https://pegawai.my.id/tasks/3/edit> di urlnya lalu isi dan disini target saya adalah akun dummy saya yang memiliki role developer juga lalu ganti description dan due datenya



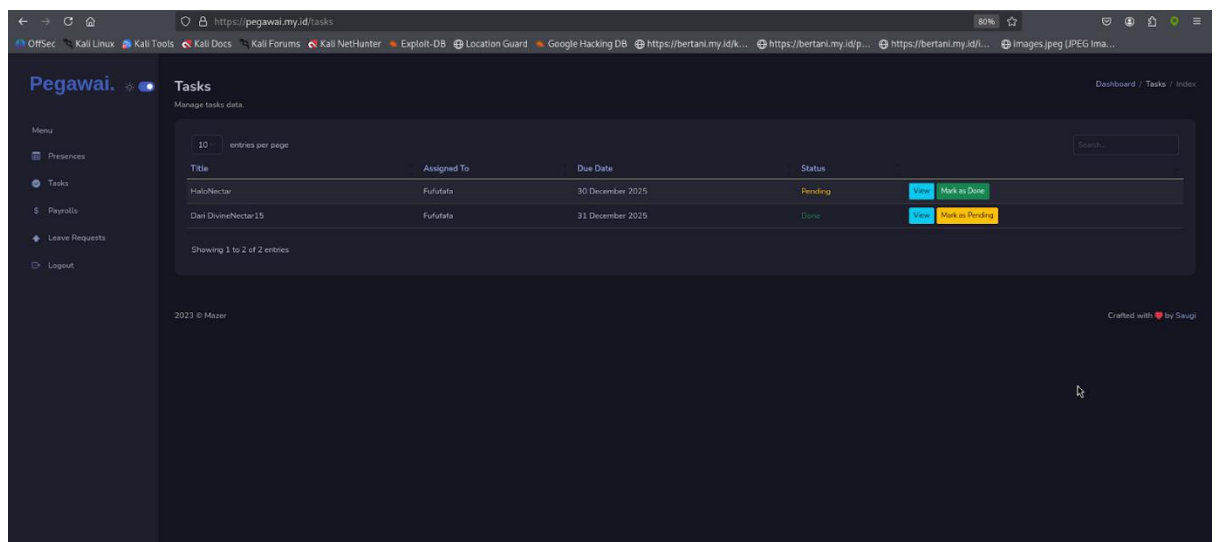
4. Tasks berhasil diedit



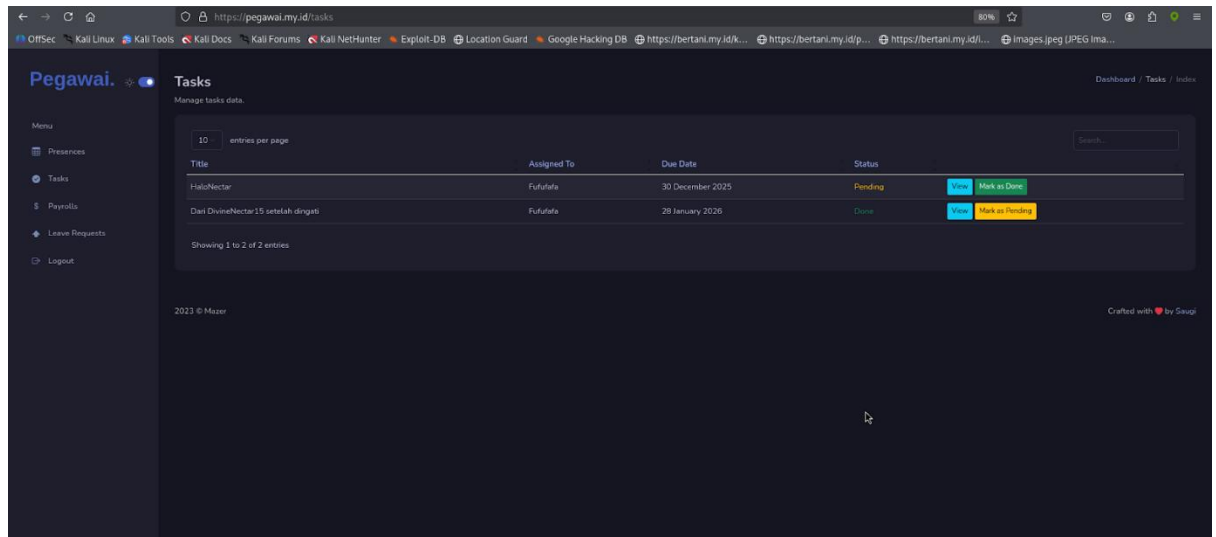
5. Lalu login ke akun dummy yang menjadi target

6. Dan tasks yang kita edit tadi berhasil terganti ke akun dummy

Sebelum di edit:



Setelah di edit



EXPECTED RESULT

Sistem seharusnya melakukan verifikasi otorisasi di sisi server (*server-side validation*) untuk memastikan apakah pengguna yang terautentikasi memiliki hak akses untuk mengedit tugas tersebut. Jika fitur tersebut tidak diizinkan untuk *role* tertentu atau jika tugas tersebut bukan milik pengguna yang bersangkutan, sistem harus mengembalikan pesan kesalahan seperti 403 Forbidden atau 404 Not Found.

ACTUAL RESULT

Sistem memproses permintaan pengeditan tugas yang dimasukkan melalui manipulasi URL tanpa melakukan pengecekan hak akses yang memadai. Pengguna dengan *role* developer berhasil memperbarui informasi tugas milik akun lain hanya dengan mengetahui ID tugas tersebut di dalam URL.

IMPACT

1. **Integritas Data Terkompromi:** Penyerang dapat mengubah informasi penting pada tugas, termasuk tenggat waktu (*due date*) dan deskripsi tugas milik rekan kerja atau atasan.
2. **Disrupsi Alur Kerja:** Pengubahan status atau detail tugas secara tidak sah dapat mengganggu koordinasi tim dan operasional perusahaan.
3. **Eskalasi Hak Akses Horizontal:** Pengguna dengan level akses rendah dapat melakukan tindakan yang seharusnya hanya boleh dilakukan oleh admin atau pemilik tugas asli

RECOMMENDATION

1. **Implementasi Otorisasi Server-Side:** Terapkan pengecekan izin (misalnya menggunakan *Policy* atau *Middleware* di Laravel) pada setiap fungsi di Controller, khususnya pada metode edit dan update.
2. **Gunakan UUID:** Pertimbangkan untuk menggunakan *Universally Unique Identifier* (UUID) sebagai pengganti ID sekuensial pada URL untuk mempersulit penyerang menebak ID objek lainnya.
3. **Prinsip Least Privilege:** Pastikan setiap *role* hanya memiliki akses ke fungsi yang benar-benar dibutuhkan untuk pekerjaan mereka.

REFERENCES

1. **OWASP Top 10:2021 – A01: Broken Access Control**
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-639: Insecure Direct Object Reference (IDOR) Prevention**
<https://cwe.mitre.org/data/definitions/639.html>